

Security+ 5.5 · Audits & Assessments

Master CyberSec — Official CompTIA Security+ (SY0-701) Comprehensive Study Guide · **Lesson 5.5 — Audits & Assessments (2:49)** · [Official YouTube Video ↗](#) · [Professor Messer Study Hub ↗](#)

Executive Lesson Summary: Audits can be internal (conducted by the company itself) or external (performed by a third party, such as a certified auditor or regulator). Reasons include verifying that controls are effective and providing assurance to customers or regulators. Compliance monitoring should be continuous, not just annual.

High-Yield Core Concepts Tested on Exam

- Internal audit = conducted by the company itself; external = by a third party
- Compliance monitoring: continuous, not just annual
- External audits provide independent verification
- Audits verify control effectiveness and provide assurance

Exam Tips & Classic Scenarios

- 'independent verification by third-party' = external audit
- If a consultancy audits the ISMS, it's an external audit

Typical Exam Scenario: An external consultancy audits the organization's ISMS. This is an example of an external audit.

Beyond the Video: Official CompTIA Exam Concepts, Protocols & Traps (Lesson 5.5 — Audits & Assessments)

Why is this advanced coverage required for SY0-701? Video overviews provide foundational familiarity, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

- **Principle of Least Privilege:** Users and computational entities must be granted only the minimum permissions strictly required to perform designated tasks.
- **Defense-in-Depth (Layered Security):** Application of multiple security controls (technical, administrative, physical) to prevent single-point perimeter compromise.

Classic CompTIA Traps & Question Framing:

- Avoid rote memorization: CompTIA exam prompts regularly adjust technical constraints requiring you to defend why one valid security control is the *MOST appropriate* or *FIRST step*.
- Scrutinize question qualifiers: 'without additional licensing costs' favors native OS tools; 'granular administrative command accounting' favors TACACS+ over RADIUS; 'non-repudiation' mandates asymmetric private key signing.

Practice Questions with In-Depth Solutions (10 Questions)

Detailed answer key with step-by-step technical rationale and comprehensive distractor breakdown provided below. Attempt answering independently first.

1. ISO/IEC 27001 is:

- A)** The INTERNATIONAL standard for information security management (ISMS)
- B)** A U.S. law
- C)** A type of firewall
- D)** A vulnerability scanner

2. Corporate scenario (Audits & Assessments): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 5.5), an analyst evaluates the following technical requirement: 'Internal audit = by the company itself; external = third party'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Implement the corresponding solution: Internal audit = by the company itself; external = third party...
- D)** Allow shared access among administrators using generic credentials

3. Corporate scenario (Audits & Assessments): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 5.5), an analyst evaluates the following technical requirement: 'Compliance monitoring: continuous period, NOT just annual'. What is the best recommendation or applicable control classification?

- A)** Implement the corresponding solution: Compliance monitoring: continuous period, NOT just annual...
- B)** Temporarily disable audit logs to accelerate system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

4. Corporate scenario (Audits & Assessments): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 5.5), an analyst evaluates the following technical requirement: '"independent verification by third-party'=external audit'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators using generic credentials
- D)** Implement the corresponding solution: 'independent verification by third-party'=external audit...

5. Corporate scenario (Audits & Assessments): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 5.5), an analyst evaluates the following technical requirement: 'external consultancy audits the ISMS' = external audit. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: 'external consultancy audits the ISMS' = external audit.
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

6. Corporate scenario (Audits & Assessments): During a security review and compliance audit aligned with the CompTIA Security+ (SY0-701, Section 5.5) exam, an analyst evaluates the following technical requirement: 'Internal audit = from the company itself; external = third party'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: Internal audit = from the company itself; external = third party...
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

7. Corporate scenario (Audits & Assessments): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 5.5), an analyst evaluates the following technical requirement: 'Compliance monitoring: continuous period, NOT just annual'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Implement the corresponding solution: Compliance monitoring: continuous period, NOT just annual...
- D)** Allow shared access among administrators with generic credentials

8. Corporate scenario (Audits & Assessments): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 5.5), an analyst evaluates the following technical requirement: 'independent verification by third-party'=external audit. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: 'independent verification by third-party'=external audit...
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

9. Corporate scenario (Audits & Assessments): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 5.5), an analyst evaluates the following technical requirement: 'external consultancy audits the ISMS' = external audit. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators using generic credentials
- D)** Implement the corresponding solution: 'external consultancy audits the ISMS' = external audit.

10. Corporate scenario (Audits & Assessments): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 5.5), an analyst evaluates the following technical requirement: 'Internal audit = from the company itself; external = third party'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: Internal audit = from the company itself; external = third party...
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials



COMPREHENSIVE ANSWER KEY & DISTRACTOR BREAKDOWN

1) A — The INTERNATIONAL standard for information security management (ISMS).

✓ **Why it is correct:** ISO/IEC 27001 is an international standard that specifies requirements for establishing, implementing, maintaining, and continually improving an Information Security Management System (ISMS). It is part of the ISO/IEC 27000 family, which addresses information security practices. The standard adopts a risk-based approach and is certifiable, allowing organizations to demonstrate compliance with global security standards. It is widely recognized and required in governance, risk, and compliance contexts, making it a relevant topic in the Governance, Risk, and Compliance domain of Security+ (SY0-701), objective 5.1.

✗ **Why the others are wrong:**

- *A U.S. law:* ISO/IEC 27001 is an international standard developed by the International Organization for Standardization (ISO) and the International Electrotechnical Commission (IEC), not a law. Laws are legislative acts of a country, such as HIPAA or GLBA in the U.S. ISO/IEC 27001 is a voluntary standard that can be adopted by organizations in any country, and its compliance is attested by certification, not by legal imposition. Confusing a standard with a law ignores the consensual and global nature of ISO standards.
- *A type of firewall:* ISO/IEC 27001 is not a security device or software, but a set of management requirements. Firewalls are network traffic control technologies, while ISO/IEC 27001 defines processes, policies, and controls for an ISMS. The standard covers organizational, human, and technical aspects, not limited to a specific technical solution. Reducing the standard to a type of firewall demonstrates a misunderstanding of its comprehensive and strategic scope.
- *A vulnerability scanner:* A vulnerability scanner is a technical tool that identifies flaws in systems, networks, or applications. ISO/IEC 27001, on the other hand, is a management standard that establishes a framework for governing information security as a whole. Although the standard may require the use of scanners as part of controls, it is not a tool. Confusing the standard with a scanner ignores its nature as a management system and its focus on continuous improvement and risk management.

2) C — Implement the corresponding solution: Internal audit = by the company itself; external = third party....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 5.5 (Audits & Assessments): Internal audit = by the company itself; external = third party. Internal audits are conducted by the organization's own staff, while external audits are performed by independent third parties.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

3) A — Implement the corresponding solution: Compliance monitoring: continuous period, NOT just annual....

✅ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 5.5 (Audits & Assessments): Compliance monitoring: continuous period, NOT just annual. Continuous compliance monitoring ensures that controls remain effective throughout the year, enabling early detection of drift, misconfigurations, and policy violations. It supports frameworks such as PCI DSS, ISO 27001, and NIST by providing ongoing evidence rather than point-in-time snapshots.

❌ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user conduct and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

4) D — Implement the corresponding solution: 'independent verification by third-party'=external audit....

✅ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 5.5 (Audits & Assessments): 'independent verification by third-party'=external audit. An external audit is conducted by an independent third party to objectively assess an organization's security posture, compliance, and controls.

❌ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* This directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* This destroys individual accountability and non-repudiation. It makes it impossible to prove who made critical changes or executed malicious commands.

5) B — Implement the corresponding solution: 'external consultancy audits the ISMS' = external audit..

✅ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 5.5 (Audits & Assessments): 'external consultancy audits the ISMS' = external audit. An external audit is an independent assessment conducted by a third party to evaluate the organization's Information Security Management System (ISMS) against standards, regulations, or frameworks. It provides objective assurance, identifies gaps, and ensures compliance with requirements such as ISO 27001, PCI DSS, or GDPR. This aligns with the governance, risk, and compliance (GRC) domain of Security+.

❌ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* This directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaches compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are

administrative controls that rely solely on user behavior and do not block automated attacks, injections, or malware at runtime.

- *Allow shared access among administrators with generic credentials:* This destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

6) B — Implement the corresponding solution: Internal audit = from the company itself; external = third party....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 5.5 (Audits & Assessments): Internal audit = from the company itself; external = third party.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

7) C — Implement the corresponding solution: Compliance monitoring: continuous period, NOT just annual....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 5.5 (Audits & Assessments): Compliance monitoring should be continuous, not just annual. Continuous monitoring ensures ongoing adherence to security policies and regulatory requirements, enabling timely detection and remediation of compliance gaps. This aligns with the requirement.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* This directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detect incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user behavior and do not block automated attacks, injections, or runtime malware.
- *Allow shared access among administrators with generic credentials:* This destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

8) B — Implement the corresponding solution: 'independent verification by third-party'=external audit....

✓ **Why it's correct:** According to the official CompTIA Security+ exam objectives (SY0-701) for lesson 5.5 (Audits & Assessments): 'independent verification by third-party'=external audit.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are

administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.

- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. It makes it impossible to prove who made critical changes or malicious commands.

9) D — Implement the corresponding solution: 'external consultancy audits the ISMS' = external audit..

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 5.5 (Audits & Assessments): 'external consultancy audits the ISMS' = external audit. An external audit is an independent assessment performed by a third party to verify that the Information Security Management System (ISMS) complies with standards such as ISO/IEC 27001, providing objective assurance of the organization's security posture.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and violates compliance standards (PCI DSS, ISO 27001).

- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.

- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

10) B — Implement the corresponding solution: Internal audit = from the company itself; external = third party....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 5.5 (Audits & Assessments): Internal audit = from the company itself; external = third party.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).

- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.

- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.